

Marcher — Sistem Güvenilirlik & Kalite Raporu

Tarih: 18 Haziran 2026

Kapsam: Backend (NestJS), Frontend (React/Vite), Altyapı, Föo ker, env, CI/CD)

Genel olgunluk: Erken üretim / küçük ekip

Canlı Fıçal ı an, iyi temelleri olan; test, CI ve gözlemlenebilirlik aç 11ndan eksikleri belirgin bir yapı Sistem tek sunucu + Docker + CloudPanel senaryosu için pratik ve üretime uygun.

Genel Skor Özeti

Alan	Skor	Durum
Mimari & kod organizasyonu	& & & & &	→
Güvenlik	& & & & &	Orta — kritik noktalar var
API & veri do ÷ ulama	& & & & &	Create güçlü, update zayıf
Hata yönetimi & gözlemlenebilirlik	& & & & &	Zayıf
Test kapsam	& & & & &	Kritik eksik
CI/CD & otomasyon	& & & & &	Yok
Dokümantasyon	& & & & &	Kök README iyi
Deployment & container	& & & & &	→
Frontend UX & erişilebilirlik	& & & & &	Orta
Ba ğımlı 1k güvenli ö	& & & & &	Orta

1. Mimari

Backend

- NestJS 11 modüler monolith: controller !' service !' Prisma
- 13 feature modülü: auth, menu, blog, campaigns, reviews, franchise, upload, vb.
- Global: Prisma, Config, Throttler, ValidationPipe
- Prisma 7 + PostgreSQL + driver adapter

Frontend

- React 19 + Vite 8 + React Router 7
- Context tabanlı (Auth, Settings)
- Public + Admin layout ayrı 1 temiz
- Admin taraf ıf ÷ tak bile övâ 6—7FVÖ' vVÆ' ıyor

Altyapı

- Informal monorepo: kök package.json ile backend/ ve frontend/ orkestrasyonu
- Tek kök .env — backend ve Vite ile paylaşımlı
- Docker Compose: Postgres + backend + frontend + nginx
- Güçlü yön: Domain modülleri net, bak 1 kolay, üretim deploy yolu tanımlanmış.
- Zayıf yön: Formal workspace yok, API dokümantasyonu (Swagger) yok, versiyonlama yok.

2. Güvenlik

–' W–wVÆ Ö Æ

- JWT + HttpOnly cookie — token taray 11 JS'inden okunamaz
- bcrypt (cost 10) ö–g&R † 6,vÆVÖP
- Helmet + CORS + rate limiting (global 100 req/dk; login 5/dk)
- Admin RBAC: JwtAuthGuard + RolesGuard
- ValidationPipe: whitelist, forbidNonWhitelisted, transform
- Franchise honeypot spam korumas
- Son admin korumas

Kritik / yüksek riskler

Risk	Önem	Aç ıÆ Ö
Blog XSS	Yüksek	BlogDetail.tsx — HTML sanitize edilmiyor
JWT secret fallback	Yüksek	JWT_SECRET yoksa dev-secret kullan Á1yor
Update DTO bypass	Orta	PUT isteklerinde nested validation atlan •or
Upload güvenli ö•	Orta	MIME/extension client'tan geliyor
Reviews veri s ı1nt 11	Orta	Gizli yorumlar da dönebilir
7 günlük JWT	Dü yÆ°	Refresh/revocation yok

3. Güvenilirlik & Hata Yönetimi

Backend

- Olumlu: Tutarlı Pxception kullan ı1 (NotFoundException, ConflictException)
- Eksik: Global exception filter yok
- Eksik: Yap Æ æA1r Æı1 ò ÆövÆ Ö •ok
- Eksik: Request/correlation ID yok
- Eksik: Health check DB ping yapm •or
- Eksik: Transaction yok — Excel import, seed atomik de ö–Ä

Frontend

- Olumlu: Admin formlarda parseApiErrors, loading state'leri
- Eksik: Public sayfalarda hata yönetimi zayıf
- Eksik: MenuDetail / BlogDetail 404 vs loading ayr ı1 yok
- Eksik: Error Boundary ve catch-all 404 route yok
- Uyarı Auth init tüm uygulamayı etkiliyor

4. Test Kapsamı

Alan	Skor	Durum
Backend unit test	0 dosya	Kritik eksik
Backend e2e	1 k !1k test	API prefix uyumsuz
Frontend test	Framework yok	0 test
CI test gate	Yok	Manuel deploy

Etkili test kapsam ~%0. Auth, guard'lar, CRUD, upload, Excel import/export test edilmiyor.

5. Veritabanı ve API

Prisma övÖ 11

- Olumlu: Net domain modelleri, enum'lar, unique slug/email
- Olumlu: Çok dilli içerik Json alanlar æF
- Uyarı Float para birimi — Decimal tercih edilmeli
- Uyarı Ek index eksik (category, status, isVisible)

API tasarımı

- Olumlu: RESTful, tutarlı ö ' &Vf—,Â ÖW kezi DTO'lar
- Eksik: Pagination/filtering, Update DTO'lar Â ' `ersiyonlama

6. Frontend Kalitesi

Güçlü yönler

- Cookie tabanlı WF, Fñ ru uygulanm _
- i18n (TR/EN/FR) public sitede iyi
- SEO: react-helmet-async
- Admin UX olgunla n1yor

Zayıflıklar

- Strict TypeScript kapalı
- Code splitting yok
- React Query/cache yok — tekrarlayan API ça r1lar
- Admin UI ço ÷VæÇV¶/Æ † &F6öFVB Türkçe

7. Altyapı ve FPvOps

Güçlü yönler

- Multi-stage Dockerfile'lar (migrate-on-start, nginx)
- Postgres healthcheck, localhost-bound portlar
- Kök README ve tek .env konvansiyonu

Eksikler

- CI/CD yok — her deploy manuel
- Husky / lint-staged yok
- .dockerignore yok
- Monitoring yok (Sentry, Prometheus vb.)

8. Öncelikli --ÆQ_tirme Planı

Acil (1–2 hafta)

1. Blog HTML sanitizasyonu — DOMPurify
2. JWT_SECRET zorunlu k Â r &öBvF `ail-fast
3. Reviews endpoint — varsay Æ â öÆ ak sadece görünür yorumlar
4. Update DTO'lar r yr W F FRðGFò 11n fÆ !1

Kısa vade (2–4 hafta)

1. Temel test suite — auth, health, CRUD smoke testleri

2. GitHub Actions — lint + build + test pipeline
3. Axios 401 interceptor
4. Health check + DB ping
5. Upload hardening

Orta vade (1–2 ay)

1. Structured logging + correlation ID
2. Strict TypeScript (frontend)
3. React.lazy + React Query
4. Transaction deste ö' „W†6VÂ –× ÷ t, seed)
5. Prettier + Husky + .dockerignore

9. Sonuç

Marcher, küçük ölçekli üretim için sa öÆ Đ temeller üzerine kurulu: modüler backend, güvenlik middleware'leri, cookie auth, Docker deploy, tek env yönetimi.

En büyük güvenilirlik aç ¶Æ !1: neredeyse s a1r test, CI/CD yok, prod gözlemlenebilirli ö• yok, blog XSS yüzeyi v update validation bypass. Acil maddeler h 'Á1ca ele al æ &–Æ— ; test + CI orta vadede en yüksek ROI'yi sa öÆ .

Rapor otomatik kod taban æ Æ—' –ÆR † j1rlanm _t " r Ö &6†W" 6öf ee projesi.

